

Granular Access Control and Delegation for DecMed Electronic Medical Records Using Macaroons

Tazkia Nizami

Informatics Study Program

School of Electrical Engineering and Informatics

Institut Teknologi Bandung

Bandung, Indonesia

Abstract—Electronic medical records (EMRs) require access control that preserves patient authority while supporting collaborative healthcare. DecMed, as a decentralized EMR framework, already uses IOTA, IPFS, and Proxy Re-Encryption (PRE), but still has three main limitations: access issuance depends on patient re-issuance, access policy remains coarse-grained and is based mainly on role and purpose, and EMR data are stored as large objects that are difficult to enforce according to the need-to-know principle. This work designs and implements an extension of granular access control on DecMed through three contributions. First, a Policy-Based Access Control (PBAC) model defines relations among actors, EMR objects, access rights, and access conditions, and is represented as Macaroon tokens with caveats. Second, off-chain EMR data are segmented by dataset category and function category so that policies can be enforced on clinical data units. Third, token attenuation supports delegation among healthcare personnel without direct patient intervention; derivative-token formation is mediated by the PRE Server so that the derived scope does not exceed the parent token. PRE serves both as a cryptographic mechanism that supports redistribution of decryption capability and as an enforcement point before encrypted data are processed. The prototype covers EMR segmentation, Macaroon tokens, enforcement on the PRE Server, IOTA Move smart contracts, and adaptations of the Patient Client and Hospital Client for outpatient and inpatient workflows involving medical record officers, nurses, physicians, laboratory officers, and pharmacists. Testing was conducted through functional scenarios P-KF-01 to P-KF-12 and non-functional tests P-KNF-01 to P-KNF-16. Within the evaluated test scenarios and prototype boundaries, the tested functional and nonfunctional requirements are considered fulfilled.

Index Terms—electronic medical records, Policy-Based Access Control, Macaroons, Proxy Re-Encryption, IOTA

I. INTRODUCTION

Electronic medical records (EMRs) enable health information to follow a patient across services, but integration also enlarges the set of parties and systems that may process sensitive clinical data. Indonesian regulation requires healthcare facilities to implement integrated EMRs, while health information is classified as specific personal data that must be protected from unauthorized processing [1], [2]. Consequently, an integrated EMR system must support data availability for care without turning a valid clinical relationship into unrestricted access.

Patient-centric access control gives patients authority over who may use their records [3]. Direct care, however, is collaborative: medical-records personnel, nurses, physicians, laboratory personnel, and pharmacists participate at different stages and require different subsets of the record [4]. The Indonesian EMR metadata guideline similarly separates outpatient, inpatient, laboratory, and pharmacy datasets and distinguishes administrative from clinical documentation [5]. These workflows require access decisions over the actor, operation, episode, data category, and time—not merely a distinction between administrative and medical personnel.

DecMed is a patient-centric decentralized EMR prototype that combines IOTA for on-chain state, IPFS for encrypted off-chain records, and proxy re-encryption (PRE) for controlled data disclosure [6]. Its previous capability token was a JSON Web Token (JWT) containing an IOTA address, a broad role, and a read/update purpose. The protected clinical record was also represented as a relatively large encrypted object. This combination created three connected limitations. First, access issuance still depended on the patient for each recipient. Second, the policy was coarse-grained because decisions were driven mainly by role and purpose. Third, the storage unit did not provide segments on which a finer policy could be enforced. The bearer-token workflow also needed evidence that the requester controlled the wallet associated with the active actor, together with revocation and audit semantics for derived grants.

This paper extends DecMed with a Policy-Based Access Control (PBAC) model, segmented EMR objects, and Macaroon capability tokens. PBAC defines the relationships among actors, EMR objects, operations, and conditions. Macaroons were selected for their append-only caveats and attenuation property, rather than on a claim that they are universally more secure than JWT, PASETO, or Biscuit. A patient still authorizes the initial access. A legitimate holder can subsequently request a narrower child token from the PRE Server, which validates the parent capability before producing the attenuation result. Macaroons conceptually allow attenuation without involving the original issuer; in this implementation, child-token formation is mediated by the PRE Server so that parent

token, delegator identity, requested scope, and delegation chain are checked before issuance. Delegation therefore does not require the patient's direct involvement at every handover among healthcare actors, but it still requires communication with the PRE Server.

The contributions are:

- 1) a PBAC-based authorization model for DecMed, represented through Macaroon caveats for read/update scope, episode, hospital, expiration, delegation depth, and parent-child attenuation;
- 2) an EMR segmentation model that aligns authorization with combinations of `dataset_category` and `function_category`; and
- 3) PRE-mediated token attenuation for delegation among healthcare actors without further patient involvement, with supporting wallet proof, institutional role/subrole checks, Redis-backed revocation, and IOTA audit records.

Section II summarizes the technical context and related work. Section III develops the problem analysis and proposed approach. Sections IV and V describe the system and its implementation. Sections VI and VII present the evidence and limitations, followed by the conclusion.

II. BACKGROUND AND RELATED WORK

A. Capability-Based Authorization and Attenuation

Capability-Based Access Control (CapBAC) represents authority as a token that identifies permitted operations over a resource; possession of a valid capability is evaluated by the resource-side verifier [7]. Policy-Based Access Control (PBAC) complements that view by making the decision criteria explicit: subjects, objects, operations, and contextual conditions are related through a policy before a capability is issued or checked [8]. In this work, PBAC defines what may be authorized, while Macaroons carry the resulting capability. Granularity therefore depends on both the policy vocabulary and the protected resource model. A token may distinguish operations and contexts, but that distinction is ineffective if the storage layer exposes only an entire record. Conversely, segmented storage does not prevent excessive access unless requests are checked against an authorization scope.

A Macaroon is a bearer authorization credential whose signature is extended whenever a first-party caveat is appended [9]. For root key K , identifier id , and caveats c_i , the signature chain is

$$s_0 = \text{HMAC}(K, id), \quad s_i = \text{HMAC}(s_{i-1}, c_i). \quad (1)$$

A holder can therefore add a restriction without learning K or removing prior caveats. Verification recomputes the chain and evaluates every caveat. This append-only property is useful for delegation because a child credential can retain all parent restrictions and add narrower ones. In the Macaroon literature, that property is often called offline attenuation because the original issuer need not mint a new root token. The DecMed implementation preserves that issuer-independent semantics

for the patient while mediating child-token formation at the PRE Server.

JWT and PASETO can carry static authorization claims, but neither format provides attenuation as a built-in operation [10], [11]. Biscuit supports attenuation and a rule language, but that language and its public-key verification model exceeded the direct attribute checks required by the DecMed prototype [12]. The choice of Macaroons in this work is thus an architectural fit: caveats encode PBAC-derived constraints, and the PRE Server remains the single verification and enforcement point.

B. DecMed Context and Research Gap

DecMed stores encrypted medical data in IPFS and records references and access state on IOTA; Umbral PRE transforms key material for an authorized recipient without exposing plaintext to the proxy [6], [13], [14]. This separates bulk encrypted data from verifiable metadata, but the previous access unit and token claims remained coarse.

Related EMR studies address complementary parts of this problem. Singh *et al.* combine role- and attribute-based controls to obtain contextual blockchain authorization [15]. Liu and Chen place role, identity, policy, and data-volume checks in a layered blockchain model [16]. Amaracitra and Alamsyah use a composable-NFT hierarchy to represent medical-record, diagnosis, laboratory, and pharmacy units separately [17]. These approaches motivate contextual policy and data decomposition, but they do not resolve the combined DecMed requirement of a patient-authorized root capability, segment-level PRE enforcement, and attenuated clinician-to-clinician delegation.

Outside healthcare, dCache demonstrates that Macaroons can constrain storage operations, paths, network context, and time windows and can be shared after adding caveats [18]. This use confirms the practicality of caveat-based attenuation in distributed storage, while leaving healthcare-specific actor authority, patient episodes, revocation chains, and wallet-bound requests to the present design.

III. PROBLEM ANALYSIS AND PROPOSED APPROACH

A. Baseline Limitations and Requirements

The previous DecMed JWT contained only address, role, and purpose, where the role was administrative or medical personnel and the purpose was read or update. It could not state a permitted dataset, clinical function, episode, expiry, or delegation depth. The medical role also did not distinguish physicians, nurses, laboratory personnel, and pharmacists. These actors have different write authority even when they participate in the same care episode.

The off-chain record compounded this limitation. One on-chain `PatientMedicalMetadata` entry referenced a comparatively large encrypted clinical object. Granting PRE processing for that object could expose more plaintext than a task required. Filtering at the client would be too late because the client would already possess the decrypted record. The enforceable resource must instead be selected before retrieval and re-encryption.

Finally, the prior grant flow ran from patient to one health-care worker and provided neither parent-child delegation nor derived-token audit. A valid-looking bearer token also did not prove that the requester controlled the wallet represented by the active identity. The resulting requirements were to (1) align token scope with segmented data, (2) distinguish read and write authority by actor and context, (3) make every derived scope monotonically no broader than its parent, (4) bind use and delegation to wallet signatures, and (5) extend revocation and audit across a delegation chain.

B. Segmented Record Model

The proposed model segments clinical data before encryption and storage. The implemented `dataset_category` values are `RAWAT_JALAN` (outpatient), `RAWAT_INAP` (inpatient), `LABORATORIUM`, and `APOTEK` (pharmacy), following the available Indonesian EMR metadata guideline [5]. Fifteen `function_category` values refine those datasets, including administrative-general data, anamnesis, physical and psychological examinations, diagnosis, therapy, supporting examinations, laboratory data, prescribing, and dispensing. Inpatient data additionally includes discharge planning.

One on-chain metadata entry refers to one encrypted off-chain segment. Metadata includes the segment and episode identifiers, patient and author wallets, hospital identifier, both categories, IPFS content identifier, ciphertext integrity hash, PRE capsule, encrypted key material, and creation time. The corresponding IPFS object contains the same contextual identifiers and the encrypted payload. This design selects an authorized segment using metadata before the PRE path can yield decryptable material.

Category caveats are complemented by institutional authority. For writes, nurses are limited to initial-examination functions in outpatient or inpatient datasets; physicians can write clinical functions for the current encounter; laboratory personnel write the laboratory dataset; and pharmacists write prescribing or dispensing data in the pharmacy dataset. Administrative personnel can create only `ADMINISTRATIVE_GENERAL` segments. The token scope and on-chain role/subrole check must both permit the operation.

C. PBAC, Macaroon Capability, and Delegation Model

The PBAC adaptation for DecMed relates users and institutional attributes to segmented EMR objects, read/update operations, and conditions such as expiry, revocation, wallet proof, and delegation depth. Macaroons then represent the issued capability; they do not replace the policy model. Table I groups the implemented caveats by the decision they support. DecMed retains separate read and update tokens. `related_rme_id` binds an update token to one care episode; a read token may cover historical segments only within its category scope. The prototype limits the root delegation depth to two, corresponding to patient-to-records-personnel issuance followed by at most two clinician delegation levels. Note that `holder_address` is not used: because Macaroons

are append-only, successive holder values cannot replace one another, so subjects are derived from `root_subject` and the `delegated_by/delegated_to` chain.

For caveat sets D_i and F_i and expiration values t_i , the PRE Server derives the effective capability as

$$D_{\text{eff}} = \bigcap_i D_i, \quad F_{\text{eff}} = \bigcap_i F_i, \quad t_{\text{eff}} = \min_i t_i. \quad (2)$$

An attenuation request is accepted only if every requested dataset and function is a subset of the parent's effective scope, the child expiry does not exceed t_{eff} , and depth does not increase. A `parent_token_hash` is appended with each child so that verification can inspect revocation keys for both the presented token and its ancestors.

Although Macaroons permit local caveat addition, this implementation asks the PRE Server to validate and produce the attenuated result. A client is not trusted to decide whether its requested scope is legitimate. The request includes a wallet-signed delegation context; PRE authenticates the parent, computes its effective capability and delegation chain, checks Redis revocation state, and consults the IOTA access snapshot before returning a child token. This mediation preserves attenuation without patient re-issuance while making PRE an explicit cryptographic and policy-enforcement boundary rather than the sole source of authorization rules.

These responsibilities map to the logical PAP, PIP, PDP, and PEP roles of a policy-based access-control architecture [19]. The mapping is logical rather than a split into four physical services: one DecMed component may realize more than one role. Policy administration (PAP) is realized when the Patient Client establishes the initial grant, the Hospital Client proposes a narrower delegation scope, and the PRE Server validates attenuation and forms child tokens whose caveats encode policy. Policy information (PIP) is distributed across Macaroon caveats, wallet proofs, IOTA role/subrole and segment metadata, Redis revocation state, and request context. The PRE Server colocates the decision and enforcement points (PDP and PEP): it evaluates access against the effective capability and external conditions, then admits or denies re-encryption; Move smart contracts on IOTA provide additional on-chain enforcement for access-state changes.

IV. SYSTEM DESIGN AND ARCHITECTURE

A. Component Responsibilities

The extension preserves the principal DecMed components and changes their authorization responsibilities. The Patient Client creates the initial consent request, signs the patient's nonce, reviews delegation history, and initiates revocation. The Hospital Client is used by records personnel and medical actors to retrieve encrypted access metadata, access permitted record segments, and request delegation. The PRE Server issues root Macaroons, validates attenuation and data requests, enforces category and institutional constraints, and performs re-encryption; in the PAP/PIP/PDP/PEP mapping of Section III, it colocates PDP and PEP. Redis stores ephemeral PRE material and revocation keys. IOTA stores personnel state,

Table I
IMPLEMENTED MACAROON CAVEATS AND THEIR ENFORCEMENT

Decision dimension	Caveats	Enforced constraint
Resource and operation	purpose, patient_address, related_rme_id, hospital_cid	Restricts a read/update token to the patient, current episode where applicable, and issuing hospital.
Data scope	read_dataset_in, write_dataset_in, read_function_in, write_function_in	Whitelists dataset/function pairs; repeated caveats are combined by intersection.
Delegation chain	root_subject, delegated_by, delegated_to, parent_token_hash	Identifies the initial holder, ordered delegation steps, active subject, and parent token used for chain validation and revocation.
Time and depth	expires_before, max_delegation_depth	Uses the earliest expiry and prevents a child from extending validity or increasing remaining depth.

segment metadata, encrypted access metadata, and delegation audit records, while IPFS stores encrypted segment objects.

Fig. 1 shows the DecMed system context retained by the extension. Patient, hospital, and ministry actors remain outside the DecMed boundary, while encrypted record objects and on-chain transactions flow to IPFS and IOTA, respectively. Within the boundary, hospital requests pass through the proxy API and authentication/access-control path before medical-record management can invoke PRE or interact with the stores. The extension therefore does not replace DecMed’s storage or PRE architecture; it narrows the conditions under which those paths execute.

B. Initial Grant

The patient remains the authority for the first grant. Records personnel display a QR value containing the hospital identifier, IOTA wallet address, and PRE public key. After scanning it, the Patient Client checks the personnel record on IOTA and lets the patient choose outpatient or inpatient service, read/update mode, and expiry. The client obtains a nonce from PRE and signs it with the patient’s IOTA key. PRE verifies the patient and confirms that the recipient is active administrative personnel at the selected hospital.

PRE then issues separate read and update Macaroons. A read token initially covers the implemented datasets and functions; an update token is limited to the selected encounter dataset plus laboratory and pharmacy and is bound to a newly generated `related_rme_id`. Both carry the hospital, recipient root subject, expiration, and maximum delegation depth. Broad root scope does not itself authorize records personnel to write clinical data because every request is also checked against their on-chain role.

The Patient Client generates the PRE data seed and encrypts it for the initial recipient. The token, token hash, encrypted seed, and access metadata are encrypted with the recipient’s PRE public key and recorded through the IOTA `create_access` function. PRE stores the associated re-encryption material in Redis with a lifetime derived from the access expiry. Thus, the ledger distributes encrypted access metadata rather than a plaintext bearer token.

C. Delegation and Request Verification

After the initial grant, records personnel may delegate to a nurse or physician. A physician may further delegate a restricted capability to laboratory personnel or a pharmacist. The root token has depth two; the first child has one remaining level, and the second-level child has zero. Presets implement task-specific scopes: a nurse receives initial-examination functions, laboratory personnel receive supporting-examination read scope and laboratory write scope, and a pharmacist receives therapy/prescription read scope and pharmacy write scope.

The delegator’s Hospital Client obtains the candidate’s public information from IOTA, decrypts the existing data seed, and re-encrypts it for the delegatee. It sends the parent token, requested scope and expiry, actor addresses, and a wallet-signed `DelegationRequestProofContext` to PRE. PRE authenticates the parent, checks all parent and ancestor revocation keys, verifies the delegator signature, computes the effective capability, and obtains an IOTA access snapshot. The snapshot confirms active accounts, a common hospital, parent validity, current depth, and the absence of a conflicting active delegation for the same recipient subrole. If the request is monotonic, PRE appends the child caveats and returns the child token and hash.

The client signs a `DelegationProofContext`, packages the child token, proof, re-encrypted seed, and metadata, and encrypts the package for the delegatee. The IOTA `create_delegated_access` function records the encrypted package and an audit entry containing delegator, root subject, delegatee, mode, episode, depth, parent and child token hashes, and expiry. The patient is not part of these steps, but the client, PRE Server, IOTA, Redis, and network are still required.

To use the grant, the delegatee decrypts its access package locally and sends the Macaroon with a request. PRE reconstructs the ordered delegation chain; the last `delegated_to` value is the active subject. It then checks chained-HMAC authenticity, expiration, depth, revocation, actor role/subrole on IOTA, and segment context. A wallet proof signs the token identifier, patient, episode, operation, segment, dataset,

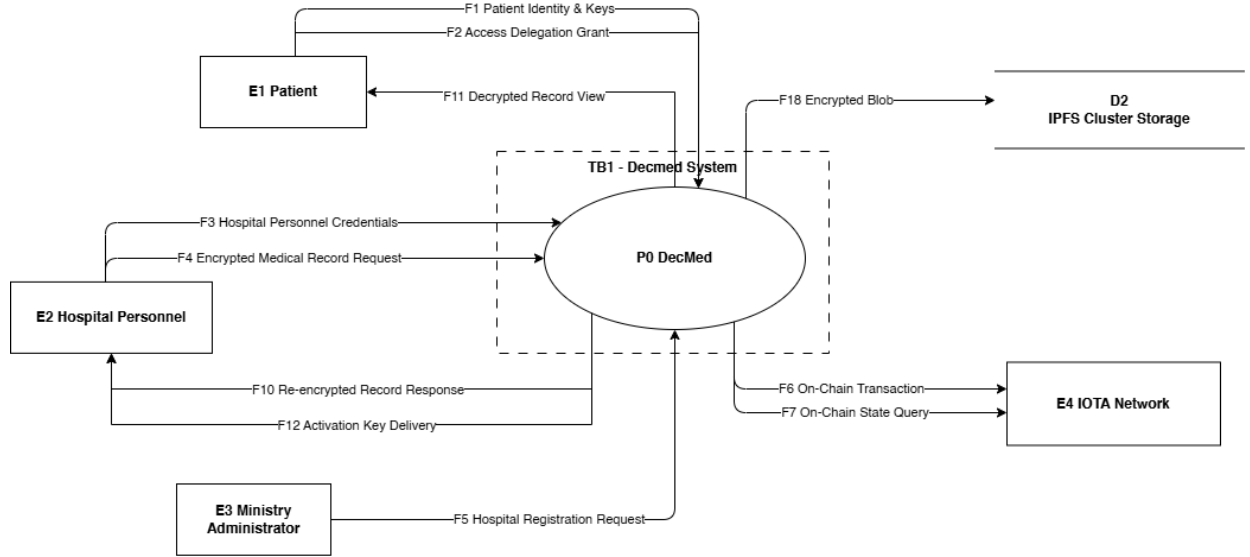


Figure 1. DecMed system context retained by the access-control extension, with patient and institutional actors, encrypted IPFS storage, and IOTA transactions (thesis artifact).

function, and timestamp. Only after the proof matches the active subject does a read trigger IPFS retrieval and Umbral re-encryption, or a write store ciphertext in IPFS and metadata in IOTA.

V. IMPLEMENTATION

The prototype was implemented mainly in Rust and retained the existing Tauri clients and IOTA Move contracts. Fig. 2 summarizes the shared packages introduced for the extension. `decmed-rme-segment` defines category enums, segment data and metadata, validation, and integrity-hash utilities. `decmed-macaroon-auth` wraps the adapted open-source macaroon crate with DecMed issuance, caveat parsing, effective-capability calculation, attenuation, chain construction, wallet-proof context, and revocation-key functions. The Patient Client, Hospital Client, and PRE Server consequently share the same segment schema; the Hospital Client and PRE Server also share authorization types.

Each `RmeSegmentData` object contains segment and episode identifiers, categories, patient and author addresses, service date, payload, and payload hash. After client-side encryption and IPFS upload, `RmeSegmentMetadata` retains the contextual fields together with the IPFS CID, ciphertext integrity hash, PRE capsule, encrypted key/nonce, hospital identifier, and creation time. The metadata is serialized as base64-encoded JSON inside the existing flat IOTA metadata list, maintaining compatibility while making categories available to PRE.

Authorization is implemented as PRE middleware plus operation-specific handlers. The middleware deserializes the bearer Macaroon, validates its chained HMAC, rejects unknown caveats, builds `EffectiveCapability` and `DelegationChain`, checks expiry and depth, and queries Redis using keys of the form `revoked:token:<hash>`.

Read and write handlers then validate the metadata or payload preview against patient, episode, hospital, dataset, function, and operation constraints. They obtain the active actor’s institutional role from the Move contract and verify the wallet signature. The accepted proof window is five minutes. On a read without a proof, PRE returns an authorization response containing the canonical context so the client can sign and retry.

Revocation combines immediate enforcement and durable state. The Patient Client first invokes the Move revocation path, which marks access and downstream delegations as revoked and records an audit event. It then asks PRE to store token hashes in Redis until token expiry and delete associated re-encryption material. When a descendant is presented, PRE checks its own hash and every `parent_token_hash`; a revoked ancestor therefore invalidates the derived request.

VI. EVALUATION

A. Environment and Method

The evaluation used a proof-of-concept deployment rather than an operational hospital system. Patient, hospital, and ministry clients and the PRE Server ran on Ubuntu 24.04.4 under WSL2 on an Intel Core i5-11400H host; WSL2 was allocated three physical cores, six logical threads, and 8 GB of the host’s 16 GB RAM. Two Ubuntu 24.04.4 VPS instances, each with eight vCPUs and 8 GB RAM, hosted supporting services. The three-peer IPFS cluster, IOTA Gas Station, and IOTA Localnet deployment were placed on the VPS infrastructure.

Evaluation traced each stated requirement to implementation evidence and a test scenario. Twelve functional tests (P-KF-01–P-KF-12) were executed manually over outpatient and inpatient workflows. The inpatient path additionally exercised the discharge-planning segment. Sixteen nonfunctional tests (P-KNF-01–P-KNF-16) combined Rust

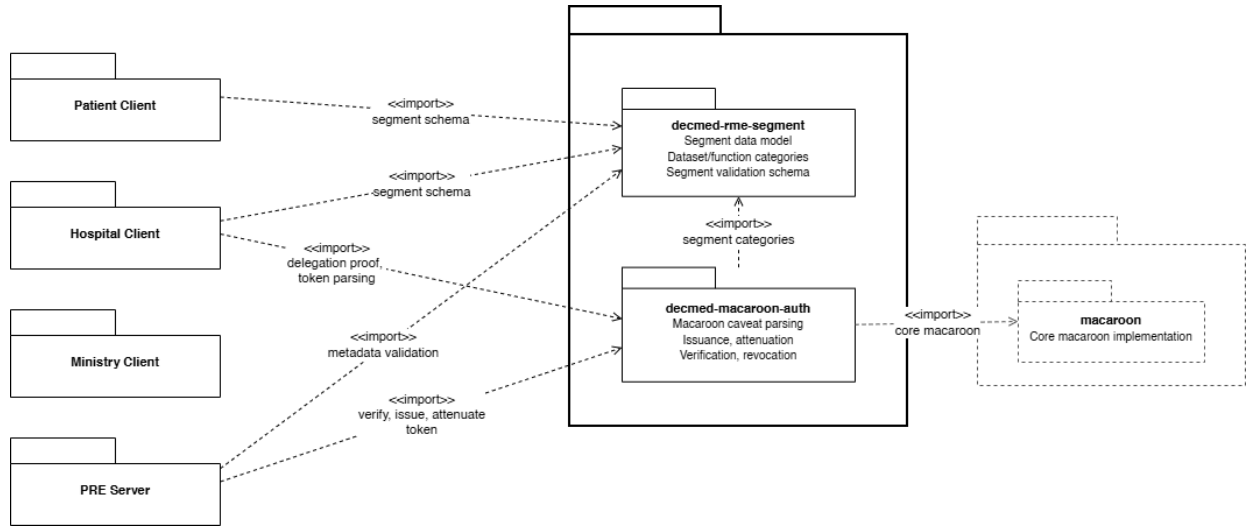


Figure 2. Shared implementation packages for segmentation and Macaroon authorization (thesis artifact).

unit/integration tests run with `cargo test` and client-level scenarios. These tests concern authorization correctness, traceability, and selected negative cases; they are not penetration tests or performance benchmarks.

Table II groups the documented scenarios without treating each user-interface step as a separate scientific result. Within the evaluated test scenarios and prototype boundaries, the tested functional and nonfunctional requirements are considered fulfilled.

B. Interpretation of Results

The positive scenarios establish an end-to-end path from an initial patient grant to task-specific access by four clinical actor types. They also connect segmentation to observable operations: the nurse writes initial examination data, the laboratory actor reads a supporting request and writes laboratory results, and the pharmacist reads prescription-related data and writes pharmacy service data. This evidence supports functional integration of category-aware authorization; it does not quantify usability or clinical effectiveness.

The negative scenarios directly exercise the main attenuation and requester-binding invariants. Dataset/function expansion, increased depth, and later child expiry were rejected. Separate cases rejected an expired token, a discontinuous delegation chain, a missing wallet signature, and a physician signature presented for a laboratory-active token. Revocation tests covered both direct token-hash lookup and use after patient-initiated chain revocation. Together, these results support correctness of the implemented authorization rules within the tested cases. They do not demonstrate resistance to all attacks, formal cryptographic correctness, or behavior under high concurrency.

VII. DISCUSSION

The results address the central mismatch in the earlier design: a PBAC-derived granular token now has a granular

storage object against which it can be enforced. PRE compares caveat intersections with on-chain segment metadata before returning re-encryption output, so an unauthorized category is rejected before the client obtains decryptable material. Institutional subrole checks further prevent a syntactically broad update token from authorizing a professional operation outside the actor’s implemented responsibility. The existing DecMed role identifier `MedicalPersonnel` continues to represent several healthcare actors; subroles distinguish nurses, physicians, laboratory personnel, and pharmacists.

PRE-mediated attenuation reduces repeated patient interaction while preserving patient control at two points: the patient authorizes the root grant and can revoke its chain. Macaroons conceptually support attenuation without the original issuer; in this system, child tokens are still formed online by the PRE Server. Delegation is therefore free of further patient involvement, but it remains a distributed transaction involving PRE validation, encrypted metadata delivery through IOTA, Redis state, and client cryptography. This improves workflow continuity only when those components are available.

PRE is a material trust and availability boundary, not the policy author. It holds the Macaroon root key, computes effective capability from PBAC-mapped caveats, validates wallets and on-chain roles, and gates re-encryption. Redis availability affects revocation and PRE material; IOTA availability affects identity, access, and audit state; IPFS availability affects ciphertext retrieval. The evaluation did not benchmark these dependencies or test large-scale failure behavior.

Other limitations follow the implemented scope. The prototype covers outpatient, inpatient, laboratory, and pharmacy datasets, represents segment payloads as text, and fixes delegation depth at two. It was evaluated locally and on VPS-hosted support services, not against a production hospital information system. The evaluation focuses on functional and authorization behavior rather than throughput, availability, scalability, broad adversarial testing, or a formal security

Table II
GROUPED EVALUATION EVIDENCE

Category	Test IDs	Tested behavior and documented outcome	Status
Initial access and delegation	P-KF-01-03, 06, 09	Patient-to-records-personnel tokens and narrower nurse, physician, laboratory, and pharmacy child tokens were created for the clinical flow.	Fulfilled
Role-scoped clinical operations	P-KF-04, 05, 07, 08, 10	Nurse initial-examination, physician clinical, laboratory, and pharmacy read/write operations processed their corresponding segments.	Fulfilled
Patient control and traceability	P-KF-11, 12	The patient viewed the delegation history and revoked access; the delegatee could no longer access the record.	Fulfilled
Out-of-scope data	P-KNF-01, 02	PRE rejected a laboratory segment outside token caveats, and a pharmacist client did not expose laboratory data.	Fulfilled
Monotonic attenuation	P-KNF-03-06	Requests that added a write function/dataset, increased depth, or extended expiry beyond the parent were rejected.	Fulfilled
Token, chain, and wallet validity	P-KNF-07-09, 13	Expired tokens, broken delegation chains, missing wallet proofs, and proofs from a non-active actor were rejected.	Fulfilled
Audit and revocation enforcement	P-KNF-10-12	Delegation details were displayed; a matching revocation key rejected the token, and root revocation removed active root and delegated access.	Fulfilled
Integrity and on-chain confidentiality constraints	P-KNF-14-16	Mismatched ciphertext integrity hashes were rejected, and clinical plaintext was not stored in on-chain metadata under the tested conditions.	Fulfilled

proof; cryptographic properties are assumed from the selected libraries and schemes. Emergency access, the emergency-department dataset, and break-glass mechanisms are outside the study and are not contributions of this work.

VIII. CONCLUSION

This work extended DecMed with a PBAC authorization model, category-based EMR segmentation, and Macaroon capabilities whose caveats constrain operation, patient, episode, hospital, data scope, expiry, and delegation chain. PRE-mediated attenuation prevents a requested child from exceeding its parent and supports delegation among health-care actors without further patient involvement, while wallet proof, role/subrole validation, Redis revocation, and IOTA audit records bind the capability to the implemented workflow. Across 12 functional tests (P-KF-01-P-KF-12) and 16 nonfunctional tests (P-KNF-01-P-KNF-16), the tested requirements are considered fulfilled within the evaluated prototype scope, and the tested out-of-scope, non-monotonic, expired, malformed-chain, wallet-invalid, and revoked cases were rejected.

The evidence supports functional correctness for the evaluated prototype, not a general claim of security or efficiency. Future work should validate the design in hospital-integrated and inter-facility workflows, add emergency/break-glass scenarios, map segments to SATUSEHAT/FHIR representations, and evaluate performance, availability, scalability, and security more extensively.

REFERENCES

- [1] Kementerian Kesehatan Republik Indonesia, *Peraturan menteri kesehatan republik indonesia nomor 24 tahun 2022 tentang rekam medis*, Jakarta, Aug. 2022.
- [2] Republik Indonesia, *Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi*, Undang-Undang, Lembaran Negara Republik Indonesia Tahun 2022 Nomor 190, Jakarta, Oct. 17, 2022. [Online]. Available: <https://peraturan.bpk.go.id/Details/229798/uu-no-27-tahun-2022> (visited on 12/20/2025).
- [3] G. Peng, A. Zhang, and X. Lin, “Patient-Centric Fine-Grained Access Control for Electronic Medical Record Sharing With Security via Dual-Blockchain,” *IEEE Transactions on Network Science and Engineering*, vol. 10, no. 6, pp. 3908–3921, Nov. 2023. DOI: 10.1109/TNSE.2023.3276166.
- [4] World Health Organization, “Framework for action on interprofessional education and collaborative practice,” World Health Organization, Geneva, Sep. 1, 2010. [Online]. Available: <https://www.who.int/publications/i/item/framework-for-action-on-interprofessional-education-collaborative-practice> (visited on 06/16/2026).
- [5] Menteri Kesehatan Republik Indonesia, *Keputusan Menteri Kesehatan Republik Indonesia Nomor HK.01.07/Menkes/1423/2022 tentang Pedoman Variabel dan Metadata Rekam Medis*, Keputusan Menteri Kesehatan, Pedoman Variabel dan Metadata Rekam Medis, Jakarta, 2022.
- [6] B. Sadewa, “Pengembangan kontrol akses dalam kerangka kerja sistem manajemen rekam medis elektronik berbasis iota,” Tugas Akhir, Institut Teknologi Bandung, 2025. [Online]. Available: https://digilib.itb.ac.id/gdl/view_data/pengembangan-kontrol-akses-dalam-kerangka-kerja-sistem-manajemen-rekam-medis-elektronik-berbasis-iota/Bakta-Sadewa (visited on 03/11/2026).

- [7] A. S. Li, R. Safavi-Naini, and P. W. L. Fong, "A capability-based distributed authorization system to enforce context-aware permission sequences," in *Proceedings of the 27th ACM Symposium on Access Control Models and Technologies*, ser. SACMAT '22, New York, NY, USA: Association for Computing Machinery, 2022, pp. 195–206. DOI: 10.1145/3532105.3535014.
- [8] D. F. Ferraiolo, S. Gavrila, and R. P. Kemp, "Policy machine: Features, architecture, and specification," National Institute of Standards and Technology (NIST), NIST IR 7987 Revision 1, Oct. 2015. DOI: 10.6028/NIST.IR.7987r1. [Online]. Available: <https://csrc.nist.gov/pubs/ir/7987/r1/final>.
- [9] A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrabie, and M. Lentczner, "Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud," in *Proceedings of the 2014 Network and Distributed System Security Symposium (NDSS)*, San Diego, CA, USA: Internet Society, Feb. 2014. DOI: 10.14722/ndss.2014.23251.
- [10] M. B. Jones, J. Bradley, and N. Sakimura, "Json web token (jwt)," Internet Engineering Task Force, RFC 7519, May 2015. DOI: 10.17487/RFC7519. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc7519>.
- [11] S. Arciszewski and S. Haussmann, *Paseto: Platform-agnostic security tokens*, Internet-Draft draft-paragon-paseto-rfc-01, Work in Progress, expired Internet-Draft, May 2022. [Online]. Available: <https://datatracker.ietf.org/doc/html/draft-paragon-paseto-rfc-01>.
- [12] Eclipse Biscuit Project. "Biscuit tokens." (), [Online]. Available: <https://www.biscuitsec.org/> (visited on 06/04/2026).
- [13] J. Benet. "IPFS — Content Addressed, Versioned, P2P File System." arXiv: 1407.3561 [cs.NI]. (Jul. 2014).
- [14] D. Nuñez, *Umbral: A threshold proxy re-encryption scheme*, Technical report, Available at <https://github.com/nucypher/umbral-doc/blob/master/umbral-doc.pdf>, 2017.
- [15] Y. Singh, S. Jaiswal, and V. Kumar, "Granular level privacy aware access control in block chain based ehr systems," in *2025 12th International Conference on Reliability, Infocom Technologies and Optimization (Trends and Future Directions) (ICRITO)*, Noida, India: IEEE, Sep. 2025. DOI: 10.1109/ICRITO66076.2025.11241459.
- [16] R. Liu and P. Chen, "Research on access control model of electronic medical records based on blockchain technology," in *2025 5th Asia-Pacific Conference on Communications Technology and Computer Science (ACCTCS)*, Huwangjia (Shanghai) Information Technology Co. Ltd and Linyi University, IEEE, 2025, pp. 662–665. DOI: 10.1109/ACCTCS66275.2025.00066.
- [17] D. S. Amaracitra and A. Alamsyah, "Decentralized medical record model using composable NFT: Achieving data security, interoperability, and privacy through granular data access," in *2025 15th International Conference on Electrical Engineering (ICEENG)*, Cairo, Egypt, May 12, 2025. DOI: 10.1109/ICEENG64546.2025.11031352.
- [18] dCache. "Chapter 1. understanding macaroons." (), [Online]. Available: <https://dcache.org/manuals/UserGuide-8.2/macaroons.shtml>.
- [19] V. C. Hu, D. F. Ferraiolo, R. D. Kuhn, *et al.*, "Guide to attribute based access control (abac) definition and considerations," National Institute of Standards and Technology, Gaithersburg, MD, NIST Special Publication 800-162, 2014, Accessed: 2026-06-03. DOI: 10.6028/NIST.SP.800-162. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-162.pdf>.